Evaluación de seguridad de software - Expedientes locales

Estudiante: Byron Bolaños Zamora | Curso: ISW-622 | Fecha: 27/10/2026

Ámbito: datos y tokens sintéticos, pruebas unitarias y peticiones HTTP únicamente en 127.0.0.1. No se utilizaron sistemas externos.

1. Requisitos, amenazas y trazabilidad

Requisitos: propiedad de lectura, segregación por sede, administrador de solo lectura, sesión válida, notas finitas de 0 a 100, rechazos sin datos sensibles, auditoría sin tokens y validación de entradas HTTP.

Amenazas: lectura ajena (alta), elevación de privilegios (alta), cruce de sedes (alta), reutilización de sesión (alta), nota corrupta (media), fuga de secretos (alta), rutas/cuerpos malformados (media).

Vínculos: lectura/IDOR: TC-01,02; sede: TC-03,06; sesiones: TC-04,08,10; roles: TC-07,09; fronteras: TC-05,11,12; confidencialidad/auditoría: pruebas adicionales. Detalle reproducible en matriz_trazabilidad.csv.

2. Doce casos automatizados (3 positivos, 6 negativos, 3 fronteras)

ID	Clase	Acción	Resultado esperado
TC-01	Positivo	Ana lee expediente 101	200, lectura permitida
TC-02	Negativo	Ana lee expediente 202	403, sin nota
TC-03	Negativo	María cambia nota en sede Pacífico	403, nota intacta
TC-04	Negativo	Ana revoca y vuelve a leer	401, sin datos
TC-05	Frontera	María introduce nota -1	400, nota intacta
TC-06	Positivo	María actualiza expediente 101 a 85	200, nota 85
TC-07	Positivo	Administrador lee ambas sedes	200 en ambos
TC-08	Negativo	Sesión expirada lee expediente	401, sin datos
TC-09	Negativo	Administrador cambia nota	403, nota intacta
TC-10	Negativo	Consulta sin token	401, sin datos
TC-11	Frontera	Nota de 100	200, se acepta
TC-12	Frontera	Nota de 101	400, nota intacta

3. Evidencia y hallazgos

Rojo inicial: 4 pruebas, 2 fallos (lectura ajena y revocación). Ciclo 1: autorización horizontal y por sede, rojo/verde/refactor. Ciclo 2: sesiones revocadas/expiradas, rojo/verde/refactor. Después se corrigieron escritura entre sedes, rango de notas, auditoría y entrada HTTP. Evidencia conservada en evidencias/.

Resultado actualizado: 34 pruebas automatizadas en el repositorio: 18 pruebas de lógica, 8 pruebas HTTP y 8 regresiones adicionales. GitHub Actions finalizó correctamente en Python 3.10, 3.12 y 3.13 (ejecución 40580311049).

4. Dictamen de liberación

Laboratorio local: APROBADO CON LIMITACIONES. Producción: BLOQUEADA. Persisten tokens sintéticos fijos, estado volátil, ausencia de TLS, identidad real, control transaccional, infraestructura y pentesting. La inspección cruzada de un segundo integrante y una reproducción independiente siguen pendientes, sin atribuirlas ficticiamente. No se garantiza una calificación.